

AgentReliabilityLab

Autonomous Cyber Alert Triage Agent

Failure Mode: When should an agent stop and hand to a human?

LangGraph

6-node

LangGraph

Hybrid RAG

RAGAS 0.923

context_recall

MITRE ATT&CK v14

6hr

CERT-In SLA

CERT-In Compliance

HITL

AgentReliabilityLab

Autonomous Cyber Alert Triage Agent

Failure Mode: When should an agent stop and hand to a human?

LangGraph

6-node

LangGraph

Hybrid RAG

RAGAS 0.923

context_recall

MITRE ATT&CK v14

6hr

CERT-In SLA

CERT-In Compliance

HITL

1 The Problem

User: SOC Analysts at Indian Enterprises and MSSPs

The primary users of AgentReliabilityLab are Level-1 SOC analysts at Indian enterprises and Managed Security Service Providers (MSSPs) — teams responsible for the first pass of cyber threat triage across hundreds of incoming alerts per shift.

SOC teams were drowning in alert volume. L1 analysts triaging hundreds of alerts per shift, most of them low-confidence noise. The decision of when to escalate to L2, when to autonomously contain, and when to close without action was being made inconsistently, under time pressure, without a structured confidence framework. CERT-In's six-hour mandatory reporting window for critical infrastructure incidents meant that delayed or wrong escalation decisions had regulatory consequences, not just operational ones.

Why This Problem Is Hard

- **Alert volume at scale.** Tier-1 analysts review 300-500 alerts per shift, with up to 45% false positive rates on EDR and IDS tools. Signal-to-noise ratio makes consistent decision-making structurally difficult.
- **Inconsistency under pressure.** The same alert triaged by two L1 analysts can receive different severity ratings 30% of the time. Human fatigue produces non-deterministic outcomes in a domain where determinism matters.
- **Missing confidence framework.** Analysts were making binary escalate/close decisions on subjective reads of alert text with no explicit confidence score and no audit record showing why.
- **Regulatory exposure.** CERT-In mandates a six-hour reporting window for critical infrastructure incidents. A delayed escalation caused by alert noise is a compliance failure with documented liability, not just an operational one.
- **Missed CRITICAL alerts are expensive.** Each missed critical alert costs an average of \$4.45M in breach response (IBM Cost of a Data Breach Report 2023).

The Core Reliability Problem

The L1 to L2 to senior analyst handoff maps directly to a confidence-threshold escalation problem: a low-confidence classification should not stall the pipeline — it should flag **human_review_required** and hand off, exactly as a Tier-1 analyst would escalate rather than guess. This handoff decision — *when to stop acting autonomously and surface the case to a human* — is the central reliability problem for any autonomous security agent. An agent that

over-escalates drowns analysts in noise. One that under-escalates lets critical incidents pass unreviewed. Both failure modes have regulatory consequences under CERT-In.

2 The Product Decisions

What Was Built

Every decision about what to build was made in service of answering a single question: *when should this agent stop and hand to a human?*

Component	Decision	Rationale
LangGraph pipeline (6 nodes)	StateGraph with conditional edges for agentic re-retrieval loop	Graph structure enforces loop bounds; conditional edges are auditable in LangSmith
Confidence-threshold escalation logic	Explicit confidence score (0-1) + confidence band (HIGH/MED/LOW)	Escalation rule is deterministic and documented, not a black-box decision
RAG-backed threat classification	Hybrid BM25 + ChromaDB dense + cross-encoder reranker	Exact technique IDs (T1486) AND semantic paraphrases both need to hit
MITRE-aligned knowledge base	MITRE ATT&CK v14, NIST CSF 2.0, CISA KEV advisories	The three reference corpora a real SOC analyst would consult
Human-in-the-loop interrupt	LangGraph interrupt_before=["audit"] for CRITICAL/HIGH alerts	Analyst can inspect full triage analysis and override before audit is written
Full audit trail per decision	Append-only JSONL with SHA-256 hash + LangSmith run ID pointer	CERT-In reporting requires documented decision chain, not a probabilistic summary

What Was Deliberately Not Built

Real SIEM integration. A production SIEM connector (Splunk, Microsoft Sentinel) was not built. The pipeline accepts raw alert text in any format. Connector-level plumbing is an infrastructure concern — it adds no insight into the reliability problem being investigated.

Autonomous remediation actions. The pipeline routes to CRITICAL/HIGH/MEDIUM/LOW/BENIGN and flags human review — it does not execute remediation (isolate endpoint, block IP, kill process). Autonomous remediation without a human checkpoint in a security context creates liability that no enterprise will accept. The product decision: the agent advises; the analyst acts.

Live threat feed ingestion. Real-time threat intelligence feeds were not connected. The knowledge base is a curated static corpus. Live feed integration is an operations engineering

problem — it does not change the fundamental escalation logic being designed and tested here.

The Two Non-Negotiables

- **No autonomous remediation without a human checkpoint.** The agent's role is to reduce decision latency and improve consistency — not to replace the analyst for consequential actions. Autonomous remediation in production security creates liability exposure that security-conscious enterprises cannot accept.
- **Audit trail is non-negotiable.** CERT-In reporting for critical infrastructure requires a documented decision chain. Every triage decision writes an append-only JSONL record with technique IDs, retrieved chunk IDs, confidence score, human override flag, and a pointer to the full LangSmith execution trace.

3 Failure Mode Addressed

When Should This Agent Stop and Hand to a Human?

The central reliability problem for autonomous agents in high-stakes domains is not capability — it is termination. Autonomous agents fail when they lack explicit termination conditions: when a loop runs unbounded, when retrieval quality degrades silently, when low-confidence output is passed forward as if it were certain.

AgentReliabilityLab is built around a single design thesis: the rules governing when to stop acting autonomously must be explicit, deterministic, and auditable. Not probabilistic. Not embedded in a black-box model. Written down and testable.

Three Classes of Termination Logic

Confidence-threshold escalation. If `confidence_score < 0.65`, the pipeline flags `human_review_required=True`. The triage decision is still returned — the pipeline does not stall — but it is marked for analyst validation. The threshold is configurable per deployment without code changes.

Bounded agentic re-retrieval loop. The graph's conditional edge allows a second retrieval pass when the LLM's self-reported confidence is below threshold. This loop is hard-capped at `MAX_RETRIEVAL_ATTEMPTS=2`. After two passes, the graph routes forward regardless. Enforcement is in the graph structure itself — not in the LLM, which cannot be trusted to self-terminate.

Technique-level hard overrides. Three MITRE technique IDs (T1486: Data Encrypted for Impact, T1490: Inhibit System Recovery, T1485: Data Destruction) trigger unconditional CRITICAL routing regardless of confidence score. A 0.65-confidence detection of T1486 is still a ransomware incident. The cost of under-escalating these techniques is non-recoverable.

The HITL Interrupt: Where the Loop Stops

LangGraph's `interrupt_before=["audit"]` pauses execution before the audit record is written for CRITICAL and HIGH alerts. An analyst reviews the full TriageAnalysis — retrieved MITRE chunks, technique IDs, confidence score, IOCs — and either approves or overrides via `POST /human-review/override`. The override is captured in the same audit record as the automated decision. This makes the human checkpoint architecturally unavoidable: the audit record cannot be written without the human signal.

Why This Failure Mode Matters Beyond Security

The termination problem is not unique to cyber triage. Any autonomous agent in a high-stakes domain — medical, financial, legal — faces the same design challenge: when the agent's confidence is insufficient for autonomous action, how does the system route to a human without stalling, without losing decision context, and without creating a compliance gap? AgentReliabilityLab builds an explicit, reusable architecture for answering that question.

4

What Success Looks Like

Product Metrics: What Would Move If This Works

Success is measurable in operational outcomes, not benchmark scores. These metrics define whether the product is working — what a SOC manager would track, not what an ML engineer would optimize.

L1 ALERT HANDLING CAPACITY	ESCALATION ACCURACY	MEAN TIME TO ESCALATION	CERT-IN COMPLIANCE RATE
Alerts / shift	Right alerts to L2	Decision latency (sec)	% complete audit trail

L1 Analyst Alert Handling Capacity

The number of alerts an L1 analyst can triage per shift before cognitive overload forces inconsistent decisions. Success means this number increases — not because analysts are

working faster, but because the agent handles benign fast-path and low-confidence alerts autonomously, reserving analyst time for genuine escalations.

Escalation Accuracy

The percentage of escalated alerts that L2 analysts confirm as warranting escalation. An agent that over-escalates adds noise to L2 queues; one that under-escalates lets genuine incidents pass. This metric is the operational definition of whether the confidence-threshold logic is calibrated correctly.

Mean Time to Escalation Decision

End-to-end latency from alert receipt to triage decision. The pipeline targets under 3 seconds. The benign fast-path (known-safe phrases resolved in ~0.4 seconds with zero token spend) disproportionately improves this metric for the majority of low-value alerts.

CERT-In Reporting Compliance Rate

The percentage of triage decisions with a complete, tamper-evident audit record at the time of any potential CERT-In reporting obligation. Any decision without a complete audit trail is a compliance failure. The append-only JSONL design with SHA-256 hashing is the mechanism that makes this metric achievable.

RAGAS Retrieval Quality (Offline Benchmark)

Retrieval quality is tracked separately from routing decision quality. If routes are wrong, RAGAS metrics diagnose whether the failure is in retrieval or in the LLM analysis layer — enabling targeted improvement without full-system retraining.

Metric	Score	What It Measures
context_recall	0.923	Were relevant chunks retrieved?
answer_relevancy	0.891	Is analysis alert-specific, not generic?
faithfulness	0.847	Is analysis grounded in retrieved chunks?
context_precision	0.814	Are retrieved chunks actually relevant?

5 One Honest Gap

AgentReliabilityLab Does Not Learn From Past Decisions

The system has no feedback loop from analyst decisions back into the knowledge base. Each triage run executes against a static corpus. A SOC that has triaged the same threat pattern 50 times gets no benefit from that history on the 51st occurrence.

The gap is real: analyst overrides contain valuable signal. When an L2 analyst overrides a LOW classification to HIGH, or closes a CRITICAL flag as a false positive, that decision is recorded in the audit log. But it does not update the knowledge base, the confidence calibration, or the retrieval index. The system is stateless across triage sessions.

Why It Was Left Out

Adaptive learning from analyst overrides would require a feedback loop from the audit log back into the RAG knowledge base. This introduces a risk that is not easily managed in a security context: **retrieval layer poisoning**. If an analyst incorrectly overrides a genuine CRITICAL alert as BENIGN — a plausible error under cognitive load — and that override propagates into the retrieval index, future alerts with the same characteristics will be under-classified. In a security context, the downstream consequence of a poisoned retrieval layer is missed critical incidents. The asymmetry of that failure mode justifies the deliberate scope boundary.

What Adaptive Learning Would Require

- A confidence-weighted feedback mechanism — overrides from high-accuracy analysts carry more weight than overrides from analysts with poor escalation track records.
- A human-in-the-loop review of proposed knowledge base updates before indexing — not automated ingestion of raw analyst decisions.
- Adversarial robustness testing to detect coordinated poisoning attempts.
- Rollback capability for the retrieval index — the ability to revert to a known-clean state if poisoning is detected after the fact.

Deliberate Scope Boundary, Not Oversight

This is a deliberate scope boundary, not an oversight. The current system solves the triage consistency and audit trail problems — the two issues with immediate regulatory and operational consequences. Adaptive learning is the right next capability, but it requires a dedicated trust and safety design process before it can be added to a production security agent.